

SCOPE DECISION LOG

Tumaini Capital Ltd | ISO/IEC 27001:2022 ISMS | Clause 4.3 — Determining the Scope of the ISMS | Fictional case study

#	Boundary Question	Options Considered	Decision	Rationale
1	Should the Kisumu office fall inside the ISMS boundary?	(a) Include — staff access in-scope systems remotely (b) Exclude — treat as a non-critical satellite office	Include	Kisumu staff have remote access to the CRM and core lending platform. Excluding a location with access to in-scope systems would leave an unmanaged interface in the risk landscape and invite challenge from a certification auditor.
2	Should the HR/Payroll system fall inside the ISMS boundary?	(a) Include now (b) Exclude for this cycle, revisit later (c) Exclude permanently	Exclude for this cycle	None of the three certification drivers (bank due-diligence requirement, ODPC enforcement focus, CRM access incident) relate to employee data. Including it would add audit and control overhead without addressing the actual risk drivers within a 12-month timeline. Employee data remains protected under baseline company policy and the Data Protection Act, 2019, and HR/Payroll will be considered for inclusion in a future ISMS review cycle.
3	How should BYOD phones be treated in scope?	(a) Include the devices themselves (b) Include only information accessed via BYOD, governed by policy (c) Exclude BYOD entirely	Policy-based inclusion (b)	The organization does not own or have technical authority over personal devices, so it cannot credibly certify device-level controls (patch levels, encryption, OS hardening). The actual risk is the organizational information flowing onto those devices. Scoping in the information — governed by an Acceptable Use/BYOD policy, conditional access, and remote-wipe of the corporate data container — while scoping out the hardware keeps the boundary honest and auditable.

METHODOLOGY

Scope was determined per Clause 4.3 of ISO/IEC 27001:2022, informed by:

- Clause 4.1 — External and internal issues (e.g. the ODPC enforcement climate, the stalled bank partnership, the CRM access incident)
- Clause 4.2 — Requirements of interested parties (e.g. the banking partner's due-diligence requirements, the ODPC, borrowers/customers)
- Interfaces and dependencies between Tumaini Capital's activities and those of external parties (AWS, the Safaricom M-Pesa API, the credit reference bureaus, the outsourced IT managed service provider)

Each boundary question was raised as part of a structured scoping discussion with the (fictional) CEO and Head of Risk & Compliance, who hold the actual sign-off authority for the documented scope statement under Clause 5.1 (Leadership and commitment). The implementer's role was to facilitate the discussion, surface the trade-offs, and draft the resulting scope statement — not to make the call unilaterally.